

Telecommunication and Networking

Topic 5
Endpoint Security

Course : Professionalism - Computing and Ethics

Instructed by : Deuk Visal

Member (Group 4) :

Sorn Sotheara
Thann Monyrosa
Tun Monireaksa
Vutthin Vatthanak
Thy Dayuth
Huon Sreynuth

Table of Contents

1. Executive Summary

- 1.1 Project Overview
- 1.2 Key Outcomes

2. Environment & Asset Analysis

- 2.1 Endpoint Inventory & Classification
- 2.2 Application Landscape (The “30 Apps” Audit)

3. Key Security Risks & Threats

- 3.1 Critical Infrastructure Risks (Ransomware & Lateral Movement)
- 3.2 Data & Compliance Risks (BYOD & Shadow IT)
- 3.3 Operational Risks (Patch Gaps & Physical Theft)

4. Technical Architecture: The Open-Source Security Stack

- 4.1 Endpoint Detection & Response (EDR): Wazuh
- 4.2 Automated Patch Management: Tactical RMM
- 4.3 Anti-Malware Integration: ClamAV & Microsoft Defender
- 4.4 Host-Based Firewall Strategy
- 4.5 Application Whitelisting: AppLocker Policies
- 4.6 Mobile Security (MDM): Headwind & Exchange Policies

5. Operational Strategy & Implementation Plan

- 5.1 Financial Feasibility (The "Zero-Cost" Model)
- 5.2 Critical Operational Workflows (Contractors & IR)
- 5.3 Phased Rollout Plan
- 5.4 User & Change Management

6. Budget Analysis & Scalability

- 6.1 Cost Savings (Open-Source vs Commercial Solutions)
- 6.2 Scalability for Future Growth

EndPoint Security Implementation Project

1. Executive Summary

1.1 Project Overview

This design proposal outlines a comprehensive **Endpoint Security Architecture** for a mid-sized Telecom organization consisting of 550 personnel (500 employees, 50 contractors) operating across a hybrid cloud and on-premise infrastructure. As the first line of defense against cyber threats, the endpoint ecosystem presents a critical attack surface that requires rigorous hardening, visibility, and control.

1.2 Key Outcomes

This architecture addresses the specific constraints of the Telecom industry—high regulatory compliance needs and a diverse workforce—by delivering three key results:

- **Zero-Trust Contractor Access:** Eliminating the risk of unmanaged vendor devices by implementing a clientless VDI workflow, ensuring no data ever resides on a contractor's personal laptop.
- **Total Visibility:** Achieving real-time monitoring of file integrity and vulnerability states across all 550 endpoints, bridging the gap between remote workers and on-premise servers.
- **Financial Efficiency:** Reducing the projected Year 1 software licensing costs from ~\$40,000 (Commercial equivalent) to **\$0**, allowing the organization to reallocate budget towards skilled personnel and infrastructure growth.

2 .Environment & Asset Analysis

This section categorizes the 550 personnel and their devices into logical groups based on risk exposure and data sensitivity.

2.1 Endpoint Inventory & Classification

Endpoint Type	User Group	Role	Ownership	Est. Count	Data Classification Risk
Laptops	Employees	Corporate Staff (HR, Finance, Sales)	Company-Owned	450	High (Contains Sensitive Data)
Laptops	Employees	IT & Engineering (NetOps, Sysadmins)	Company-Owned	50	Medium (On-premises)
Mobile Phones	Employees	Corporate Staff	BYOD	500	Very High (Data Co mingling)
Laptops	Contractors	Contractors (3rd Party Vendors)	BYOD	50	Critical (Untrusted Devices)
Servers	Infrastructure	Infrastructure (Billing/Web/DB)	On-Premises / Cloud	30	High (Critical Infrastructure)

Summary

- Standard Laptop (400 Users):** Used by HR, Finance, and Sales. Classified as **Medium Risk** due to exposure to phishing. The security focus is **Automated Patching** (Tactical RMM) to close vulnerabilities within 24 hours and **Web Filtering** to block social media and malicious sites.
- Admin Workstation (50 Users):** Used by Sysadmins with "Root" access. Classified as **High Risk** because a compromise here affects the whole company. We enforce **MFA** on every login and use **AppLocker** to block any non-administrative tools.
- Mobile Phone:** Android devices used by tower technicians. Classified as **Medium Risk** (Physical Theft). We enforce **Kiosk Mode** (locking the device to Maps/Ticketing apps only) and **Full Disk Encryption** so stolen data cannot be read.

4. **BYOD Laptop (50 Users):** Personal devices used by Contractors. Classified as **Critical Risk** as they are unmanaged and potentially infected. We utilize **Clientless VDI (Apache Guacamole)** to isolate them completely from the network—they see a video stream of the app, but no data touches their device.
5. **Hybrid Servers (30 Units):** The core infrastructure (On-Prem & Cloud). Classified as **High Risk**. We install **Wazuh Agents** specifically configured for **File Integrity Monitoring (FIM)** to trigger an immediate alarm if any system file is modified.

2.2 Application Landscape (The “30 Apps” Audit)

App Category	Description & Examples	User Base	Criticality
Core Productivity	Standard business tools. (Office 365, Teams, Adobe Reader, Zoom)	All 550 Users	Medium
Telecom Business	Critical operational software (Amdocs Billing, Salesforce CRM, Tower Map Tool)	Corporate & Field	High (Revenue Impact)
IT Management	Dangerous admin tools. (PuTTY, Wireshark, PowerShell ISE, WinSCP)	IT Dept Only (50)	High (Security Risk)
Browser/Web	Internet access tools. (Google Chrome, Microsoft Edge)	All 550 Users	Medium

Summary

1. **Core Productivity:** We use **Publisher Rules** to allow apps digitally signed by trusted vendors. This ensures that when app updates, the signature remains valid and the whitelist doesn't break
2. **Telecom Business:** Custom industry software often lacks digital signatures. We use **Path Rules** to allow executables only if they are in the protected **C:\Program Files\TelecomApp** directory, which standard users cannot modify.
3. **IT Management:** Dangerous admin tools are restricted via **Group Policies**. They will only launch if the logged-in user is a verified member of the "IT_Admins" Active Directory group.
4. **Browser/Web:** We allow the browser executable via Publisher Rule but strictly enforce **Extension Whitelisting** to prevent users from installing malicious add-ons or spyware.
5. **Implicit Deny:** The most critical rule. Any file not matching the above categories is **automatically blocked** by default.

3. Key Security Risks & Threats

3.1 Critical Infrastructure Risks (Ransomware & Lateral Movement)

A failure in endpoint security directly threatens the CIA Triad: **Confidentiality, Integrity, and Availability**. Our endpoint security design addresses and mitigates the following major risks:

- **Risk 1: Ransomware:** An unpatched contractor laptop connects to the company network and bypasses basic firewall protections. Because the device contains known vulnerabilities, attackers can deploy ransomware and encrypt critical company servers, severely impacting business operations.
- **Risk 2: Data Exfiltration (Compliance Risk):** An employee uses a personal BYOD mobile phone to copy and share “Sensitive” customer data. This unauthorized data transfer violates Data Compliance laws (PCE PDF 9) and exposes the company to legal, financial, and reputational consequences.
- **Risk 3: Lateral Movement:** A compromised employee laptop becomes an attacker’s initial entry point (“beachhead”). After gaining control of that device, the attacker moves laterally across the network and accesses segmented zones (PCE PDF 3), eventually reaching more sensitive systems.
- **Risk 4: Physical Theft:** A company laptop is stolen. Without full-disk encryption (Data-at-Rest protection), all stored information is exposed. This incident qualifies as a major data breach and may require a formal PIPIA process (PCE PDF 9) and mandatory notification to affected parties.

3.2 Data & Compliance Risks (BYOD & Shadow IT)

Unmanaged personal devices and unauthorized applications create exposure to data leakage and regulatory violations. Without proper controls, company data may be accessed or stored on untrusted BYOD devices, increasing compliance and privacy risks.

3.3 Operational Risks (Patch Gaps & Physical Theft)

Delayed security updates and missing patches leave endpoints vulnerable to exploitation. Physical loss or theft of laptops also threatens data confidentiality when encryption and remote-wipe protections are not enforced.

4. Technical Architecture: The Open-Source Security Stack

4.1 Endpoint Detection & Response (EDR): Wazuh

Wazuh is deployed on all endpoints to monitor activity and detect suspicious behaviour in real-time. Alerts are centralized for quick investigation and response. This improves visibility and reduces the risk of undetected threats.

4.2 Automated Patch Management: Tactical RMM

Tactical RMM ensures all endpoints are regularly updated with the latest patches. Automated updates reduce vulnerabilities and minimize operational gaps. Reports help track compliance and identify unpatched devices.

4.3 Anti-Malware Integration: ClamAV & Microsoft Defender

ClamAV and Microsoft Defender provide layered malware protection across all devices. Regular scanning prevents infections and complements EDR monitoring. Alerts are integrated to respond quickly to threats.

4.4 Host-Based Firewall Strategy

All endpoints use host-based firewalls with a “Default Deny” policy. Unauthorized connections are blocked, reducing exposure to network attacks. Firewall rules are monitored and updated regularly for effectiveness.

4.5 Application Whitelisting: AppLocker Policies

AppLocker enforces execution of only approved applications on endpoints. This minimizes the risk of malware and unapproved software. Policies are updated to include new business-approved applications.

4.6 Mobile Security (MDM): Headwind & Exchange Policies

All mobile devices are enrolled in Headwind MDM and secured with encryption and containerization. Corporate apps and data are separated from personal use. Remote-wipe ensures lost or stolen devices do not expose sensitive information.

5. Operational Strategy & Implementation Plan

To translate our technical architecture into reality, we require a rigid operational strategy. This plan avoids a disruptive "**big bang**" deployment by utilizing a risk-prioritized phased rollout. It aligns specific Open-Source tools to the identified risks while establishing clear regulatory boundaries for personnel.

5.1 Financial Feasibility (The "Zero-Cost" Model)

The design ensures financial viability by prioritizing **Cost Avoidance** over Capital Expenditure (CapEx). By leveraging open-source alternatives to commercial equivalents, we achieve enterprise-grade security with **\$0 in software licensing fees**.

Cost Component	Commercial Solution	Open Source Stack	Financial Impact
Endpoint	\$27,500/yr (\$50/user)	Wazuh Agent (GPL License)	\$27,500 Saved
Patch Management	\$8,250/yr (\$15/user)	Tactical RMM (Open Source)	\$8,250 Saved
Contractor Hardware	\$50,000 (50 Laptops @ \$1k)	Apache Guacamole (Clientless VDI)	\$50,000 Saved
Server Infrastructure	Cloud SaaS Fees	Existing On-Prem Hardware	\$0 (Sunk Cost)
			~\$85,750 Saved

Feasibility Verdict: This model shifts budget from "Software Rent" to "Talent Retention," allowing the company to invest in Security Operations staff rather than vendor subscriptions.

5.2 Critical Operational Workflows (Contractors & IR)

These workflows define exactly how the systems and humans interact to mitigate high-priority risks.

A. Contractor "Zero Trust" Access Workflow (Mitigating Risk 1: Ransomware)

- a. **The Problem:** Contractors bringing unmanaged, infected laptops onto the network.
- b. **The Tool: Apache Guacamole** (Clientless Remote Desktop Gateway).
- c. The Workflow:
 - i. **Authentication:** Contractor logs into the Web Portal using MFA.
 - ii. **Session Creation:** The Guacamole server spins up a disposable "Containerized Browser" session.
 - iii. **Isolation:** The contractor interacts with the Billing App via video stream. **No data packets** travel between the contractor's laptop and the Billing Server, only pixels.
 - iv. **Termination:** When the session ends, the container is destroyed. Any malware introduced during the session is wiped.

Regulation 1 (For Contractors): The "Clean Access" Policy *"External personnel are strictly prohibited from using VPN clients or bridging personal devices to the corporate LAN. Access to internal resources is permitted SOLELY via the provided Web VDI Portal. Any attempt to bypass this portal will result in immediate contract termination."*

B. Automated Incident Response (Mitigating Risk 3: Lateral Movement & Risk 6: Privilege Escalation)

- a. **The Problem:** Human response is too slow to stop a "Beachhead" attack or Admin abuse.
- b. **The Tool: Wazuh "Active Response" Module.**
- c. **The Workflow:**
 - i. **Trigger:** Wazuh detects a "High Confidence" threat (e.g., specific Ransomware file extension creation or Antivirus service disabled).
 - ii. **Automated Action:** The agent executes a local script:


```
route add 0.0.0.0 mask 0.0.0.0 127.0.0.1.
```
 - iii. **Result:** The device is instantly cut off from the network (Internet & LAN) but remains connected to the Wazuh Manager for forensics.
 - iv. **Alert:** A "Critical Severity" ticket is pushed to the SOC.

Regulation 2 (For Employees): The "Tamper-Proof" Policy *"Employees must not attempt to disable, pause, or uninstall the Wazuh Security Agent or Windows Defender. The system is configured to detect 'Silence'—if an agent stops reporting for 5 minutes, the user's account will be automatically locked pending IT investigation."*

5.3 Phased Rollout Plan

We will deploy the solution in three sprints over 5 weeks. This allows us to validate the "Problem-Solution" fit before scaling.

1. Phase 1: Foundation & Visibility (Week 1)

- a. **Target:** 50 IT & Engineering Staff (High Skill / High Risk).
- b. **Goals:** Stop **Risk 5 (Shadow IT)** and **Risk 6 (Admin Abuse)**.
- c. **Implementation Steps:**
 - i. **Deploy Wazuh:** Install agents on all Admin workstations to establish a baseline of "Normal Activity."
 - ii. **AppLocker "Audit Mode":** Deploy the Whitelist policy but set it to *Log Only*. This reveals every unauthorized tool IT staff are using without breaking their workflow.
 - iii. **VDI Setup:** Provision the Apache Guacamole server for Contractors.

Success Criteria: 100% of IT assets are reporting to the dashboard; Shadow IT report generated.

2. Phase 2: Core Hardening (Weeks 2-4)

- a. **Target:** 400 Corporate Staff (HR, Finance, Sales).
- b. **Goals:** Stop **Risk 3 (Lateral Movement)**, **Risk 4 (Theft)**, and **Risk 8 (Patch Gap)**.
- c. **Implementation Steps:**
 - i. **Patch Automation:** Enroll all devices in **Tactical RMM**. Configure "Critical Updates" to install daily at 12:30 PM (Lunch).
 - ii. **Firewall Logic:** Push Group Policy to block all *Inbound* connections (stopping Lateral Movement).
 - iii. **Encryption:** Remotely trigger **BitLocker** encryption on all laptops. Save recovery keys to the central RMM database.
 - iv. **AppLocker "Enforce Mode":** Switch the switch. Unauthorized apps (games, scripts) will now fail to launch.

Success Criteria: 95% Patch Compliance Rate; 0 unencrypted laptops.

3. Phase 3: The "Edge" & BYOD (Week 5)

- a. **Target:** 50 Field Techs & 50 Contractors.
- b. **Goals:** Stop **Risk 1 (Ransomware)**, **Risk 2 (Data Exfiltration)**, and **Risk 7 (MITM)**.
- c. **Implementation Steps:**
 - i. **Contractor Cutover:** Revoke all legacy VPN accounts. Direct all 50 contractors to the new Web VDI Portal.
 - ii. **Mobile Enrollment:** Field Techs scan a QR code to enroll Android tablets in **Headwind MDM**.
 - iii. **Kiosk Enforcement:** Push the policy to lock tablets to "Maps" and "Tickets" only.
 - iv. **Exchange Policy:** Activate "Block Copy/Paste" on the Email Server for personal phones.

Regulation 3 (For Mobile Users): The "Device Hygiene" Policy

"Corporate data accessed on personal devices via Email or Teams is monitored. Users are prohibited from copying corporate contacts or data into personal cloud storage (iCloud/Google Drive). The system will automatically block these actions."

5.4 User & Change Management

Security projects often fail because users hate the new restrictions. We will manage this culture shift proactively.

1. Communication Strategy:

- **"The Why":** We will explain that **Risk 1 (Ransomware)** puts *their* payroll at risk. This system protects their ability to get paid.
- **Transparency:** We will clarify that **Wazuh** monitors *security events* (viruses, crashes), not *productivity* (it does not read their personal emails or track bathroom breaks).

2. Training Workshops:

- **For Contractors:** A mandatory 15-minute webinar: "How to access the Billing App via the new Web Portal."
- **For Staff:** A "Safe Browsing" guide explaining why AppLocker blocked that random PDF converter they tried to download.

3. Support Structure:

- During **Phase 2 (Enforcement)**, IT will operate a "**Fast Track**" **Whitelist Request** queue. If a legitimate business app is blocked by AppLocker, it will be reviewed and whitelisted within 1 hour to prevent work stoppage.

6. Budget Analysis & Scalability

6.1 Cost Savings (Open-Source vs Commercial Solutions)

- Open-source tools reduce software licensing costs significantly.
- Savings can be reinvested into infrastructure, staff training, or advanced security controls.
- Maintains strong protection without large capital expenditure.

6.2 Scalability for Future Growth

- Cloud-based tools allow instant enrollment of new endpoints and users.
- Policies and monitoring scale automatically across hybrid environments.
- Supports company growth without compromising security or compliance.